TENDERHUB ENGINEERING PUBLICATIONS • TECHNICAL REPORT SERIES

TenderHub Cloudflare Anti-Bot & Scraping Defense Plan

Edge Security Architecture, WAF Rulesets, Bot Fight Mode, and Turnstile Integration

Author: Lead Systems Architect **Date:** October 2026 **Classification:** Internal Technical Manual **Version:** 2.4.0

ABSTRACT

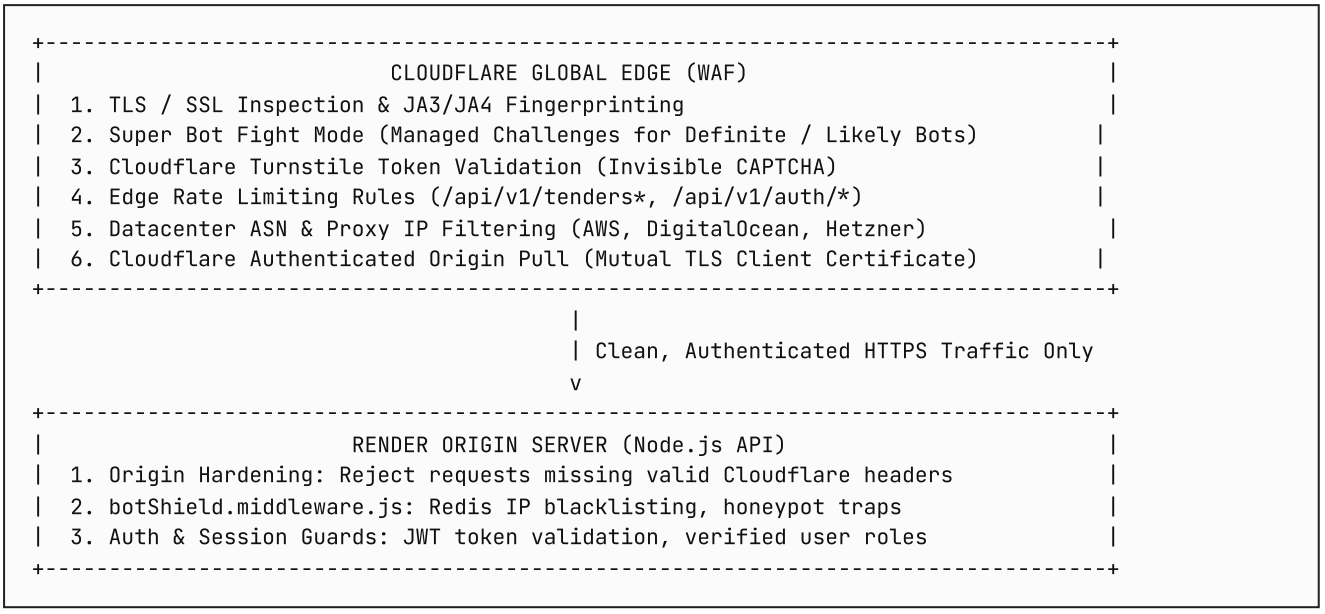
Comprehensive security plan and implementation runbook for deploying Cloudflare Edge Bot Management, WAF custom rulesets, Cloudflare Turnstile invisible CAPTCHAs, and Cloudflare R2 asset hotlinking protection.

1. Executive Summary & Threat Model

As an intelligence aggregator of government procurement notices, TenderHub is vulnerable to automated competitor scraping, catalog harvesting, credential stuffing, and Cloudflare R2 document bandwidth leeching.

While application-level middleware (`botShield.middleware.js`) intercepts known User-Agents, every bot request reaching Node.js consumes Render compute cycles, memory, and database connections. **Cloudflare Edge Defense** intercepts, challenges, and drops malicious requests at Cloudflare's global anycast points of presence before packets ever touch the Render origin server.

2. Multi-Layered Edge Defense Architecture



3. Six-Phase Implementation Roadmap

Phase 1: Cloudflare Proxy & Origin Hardening

- **DNS Orange-Cloud Proxying**: Route `tenderhub.in` and `api.tenderhub.in` through Cloudflare proxy.
- **SSL/TLS Full (Strict)**: Enforce Minimum TLS Version 1.2 with HTTP/3 QUIC.
- **Origin Pull Hardening**: In `botShield.middleware.js`, verify incoming requests in production contain `cf-ray` and `cf-connecting-ip` headers to prevent direct IP bypass.

Phase 2: Super Bot Fight Mode Configuration

Traffic Classification	Cloudflare Edge Action	Target Scenarios
Definitely Automated	Block	Python `requests`, Scrapy, curl, unauthorized exploit bots
Likely Automated	Managed Challenge	Headless Playwright / Puppeteer scrapers lacking full browser DOM
Verified Search Bots	Allow	Googlebot, Bingbot for public SEO tender indexing

Phase 3: Edge WAF Custom Rules & Scraper Defense

- **Tender Catalog Harvesting Rule**: Limit `GET /api/v1/tenders*` to 25 requests per 10 seconds per IP address; challenge excess requests with Turnstile for 5 minutes.
- **Auth Brute-Force Rule**: Limit `POST /api/v1/auth/login` and `register` to 5 requests per 60 seconds per IP; block violators for 1 hour.
- **Datacenter ASN Filtering**: Challenge requests originating from hosting providers (AWS, DigitalOcean, Hetzner, OVH) attempting to query user-facing APIs without a valid session.

Phase 4: Cloudflare Turnstile Integration (Invisible Bot Challenge)

Cloudflare Turnstile replaces traditional intrusive image CAPTCHAs with an invisible cryptographic challenge verifying genuine human browsers.

- **Frontend Widget**: Embed invisible Turnstile container on `/login`, `/register`, and tender document download modals.
- **Backend Middleware**: Express middleware validates `cf-turnstile-response` token against Cloudflare Siteverify API (`https://challenges.cloudflare.com/turnstile/v0/siteverify`).

Phase 5: Cloudflare R2 Document Hotlinking & Asset Security

- **Ephemeral Presigned URLs**: All tender document download links are generated with strict 15-minute expiration (`expiresIn: 900`).
- **WAF Referer Header Enforcement**: Block direct hotlinks to document assets unless the HTTP Referer originates from `tenderhub.in`.

Phase 6: Operational Monitoring & Analytics

Continuously monitor blocked threat metrics in Cloudflare Dashboard (Security → WAF → Events) to fine-tune rate-limiting thresholds without false positives for legitimate contractors.

4. Environment Variables Checklist

```
# Backend (backend/.env)
TURNSTILE_SECRET_KEY=[REDACTED]
CLOUDFLARE_ORIGIN_VERIFY_SECRET=[REDACTED]

# Frontend (frontend/.env.production)
VITE_TURNSTILE_SITE_KEY=0x4AAAAAA...your_turnstile_site_key...
```